

On a Roll:

A One-Query Universal Forgery against Poulakis–Rolland v2

Martin Feussner

Selmer Center, University of Bergen

`martin.feussner@uib.no`

9 October 2026

AI provenance and review status. This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex generated and selected this paper’s title. It intentionally chose “On a Roll” as wordplay on Rolland. OpenAI Codex and specialist AI agents performed the target reconstruction, cryptanalysis, implementations, experiments, technical and adversarial review, history search, and drafting. An independently developed AI implementation reproduced the attack with new full-parameter key material. The technical, adversarial, independent-reproduction, history, and publication-review gates passed; this report is classified `VERIFIED_ATTACK`. Independent AI reproduction is not described as human verification.

Abstract

We give a one-query universal fresh-message forgery against the second revision of the composite-order pairing signature of Poulakis and Rolland, IACR ePrint 2012/134, revision 20150430:055329. Section 4 maps a message to $H(m) = [\kappa_m]G_H$, where the fixed group generator and the rejection-sampled scalar κ_m are public. From one ordinary signature (s_0, S_0) , an attacker keeps s_0 unchanged and scales S_0 by a public factor involving κ_1/κ_0 and $g^{h(m_1)-h(m_0)}$. Bilinearity then turns the source verification equation into the equation for an arbitrary fresh target. The attack does not factor n , solve a discrete logarithm, reuse a nonce, exploit malformed encoding, or weaken verifier checks.

We reproduce the attack with the paper’s 1023/1024-bit printed factors, 2046-bit composite order, 2048-bit field, supersingular curve, and a complete modified reduced Tate pairing. A second implementation generates a new exact-order subgroup generator, secret exponent, public key, and signing split at that endpoint. Both ordinary pairing verifiers accept fresh forgeries, while changed-message, point, scalar, identity, and non-subgroup controls reject. The generic public-scalar transport is known from Tibouchi’s 2011 analysis of insecure BLS hash-to-group constructions; we claim no novelty for that technique. Our contribution is its concrete application and full-parameter validation against Poulakis–Rolland v2.

Result status. Practical full-parameter design attack: one ordinary chosen-message query yields fresh-message signatures accepted by the ordinary verifier. No exact-target v2 attack was located in the searches completed as of 9 October 2026. This is a dated search result, not an absolute priority claim.

1 Introduction

Poulakis and Rolland propose a signature intended to retain security unless both integer factorization and an elliptic-curve discrete logarithm problem become tractable [1]. Its public key combines an RSA-like composite $n = p_1p_2$, exponentiation in $\mathbb{Z}_n^*$, an order- n elliptic-curve subgroup, and a bilinear pairing. The second revision replaced the first version’s signing equations with a randomized split $k + \ell = a$ and a new pairing verification equation.

The second revision nevertheless specifies a map to the elliptic-curve group whose output has a publicly known discrete logarithm relative to a fixed public point. This representation is enough to transport a valid signature between messages. One source query produces a signing response that can be rescaled for any fresh message for which the advertised affine signature encoding is defined.

Our contributions are as follows.

- We derive a same-response attack that transforms one ordinary v2 signature into a signature on any distinct encodable target. Because the integer response is copied verbatim, every range check passed by the source signature is preserved.
- We give a second algebraic form that reconstructs a message-independent point and selects a target using a public range bound.
- We execute complete 2048-bit-field pairing verifiers in two standard-library implementations. The independent implementation creates new full-parameter curve and key material and tests malformed-point and non-subgroup controls.
- We separate the attack from defects in the paper’s printed example, from underspecified encodings, and from the already-broken first revision. We give a direct repair boundary and explicit prior-art attribution.

Attack-history statement. The dated search covered the exact title, authors, ePrint identifier and revision, citations to the target, public code, theses, and terms concerning forgery, public-scalar maps, hash-to-curve, and BLS-style transport. It located the generic technique described below, but no public report applying it to the exact v2 construction. Unindexed and private observations cannot be excluded, so this report makes no absolute first-attack claim.

Technique attribution. Boneh, Lynn, and Shacham introduced their pairing-based short-signature scheme in 2001 [3]. Tibouchi’s 2011 thesis, Section 3.2, pages 38–40, analyzes the insecure construction $H(m) = [h(m)]G$ and its variant $H(m) = [h(m)]Q$ [2]. For the latter, one known signature can be scaled by $h(m)/h(m_0)$ to sign arbitrary messages even when the discrete logarithm of Q relative to G is hidden. Poulakis–Rolland v2 adds a scalar response and message-dependent powers of g , but those terms are public and can be included in the same transport. We claim no novelty for public-scalar BLS transport.

2 Exact target and version boundary

The target is IACR ePrint 2012/134, revision 20150430:055329 [1]. The audited PDF has SHA-256 digest

a8b4eae608a28baf86e585fb19056a43881d3c386eae6f7fb6b2cf1d2d49c65f.

The archived author-source gzip has SHA-256 digest

d67435736b459ef85c705dd726763204ac6400b3c3c9058ac2a2b2e25011ae86.

The revision record states that the first version was broken. Version 1 is a materially different system: its public key includes additional points and a public scalar $r = g^b$, its point response is the static $S = [g^{ab}]H(m)$, its scalar is $s = bh(m) + a - ab \pmod{\varphi(n)}$, and its verifier checks two relations. Version 2 instead uses a fresh split $k + \ell = a$ and the equations in Section 3. Consequently, an attack or regression test for v1 does not establish a v2 break. All claims below are derived from and executed against v2.

3 The v2 scheme

Key generation chooses $n = p_1 p_2$, an elliptic-curve point P of exact order n , a bilinear pairing e_n such that $e_n(P, P)$ has order n , a unit $g \in \mathbb{Z}_n^*$, and a secret $a \in \{1, \dots, \varphi(n) - 1\}$. It publishes

$$Q = [g^a \bmod n]P$$

and the public key (P, Q, g, n) . The notation $[z]X$ denotes scalar multiplication in the additive elliptic-curve subgroup.

To sign m , the signer chooses positive k, ℓ with $k + \ell = a$ and computes

$$s \equiv k + h(m) + n \pmod{\varphi(n)}, \tag{1}$$

$$S = [g^\ell \bmod n]H(m). \tag{2}$$

The signature contains $(s, x(S), b(S))$, where the bit selects one of the two points at the affine x -coordinate. The verifier reconstructs S and accepts when

$$e_n([g^s]P, S) = e_n([g^{h(m)+n}]Q, H(m)). \quad (3)$$

3.1 The public-scalar map

Section 4 fixes a public generator of the order- n group, called Q in that section. To avoid confusing it with the public-key point $Q = [g^a]P$, we call the map generator G_H . A public KDF is evaluated on $m \parallel T_i$ until the resulting $|n|$ -bit integer is smaller than n , and the algorithm outputs

$$H(m) = [\kappa_m]G_H. \quad (4)$$

Anyone who can evaluate H necessarily computes the accepted κ_m . Hiding the discrete logarithm of G_H relative to P does not hide ratios between map outputs.

4 One-query universal forgery

The adversary first chooses a source message m_0 for which $\gcd(\kappa_0, n) = 1$. This condition is publicly testable before making a signing query. Under the stated pseudorandom behavior its failure probability is approximately $1/p_1 + 1/p_2$; a nontrivial gcd also reveals a factor of n . The adversary obtains one ordinary signature $\sigma_0 = (s_0, S_0)$ on m_0 .

For any distinct target message m_1 , define

$$\Delta h = h(m_1) - h(m_0), \quad (5)$$

$$\mu = \kappa_1 \kappa_0^{-1} g^{\Delta h} \pmod{n}, \quad (6)$$

$$s_1 = s_0, \quad (7)$$

$$S_1 = [\mu]S_0. \quad (8)$$

For negative Δh , the attacker exponentiates the public inverse of g modulo n . The output is encoded in the same (s, x, b) format as an honest signature.

Theorem 1. *If σ_0 is an honest signature on m_0 , $\gcd(\kappa_0, n) = 1$, and $H(m_1)$ is representable in the advertised affine format, then the signature (s_1, S_1) from Equation (8) is accepted for m_1 by Equation (3).*

Proof. For the signing split $k + \ell = a$, Equations (4) and the signing algorithm give

$$S_0 = [g^\ell \kappa_0]G_H, \quad S_1 = [g^{\ell+\Delta h} \kappa_1]G_H.$$

Because $s_0 \equiv k + h(m_0) + n \pmod{\varphi(n)}$ and g is a unit modulo n ,

$$g^{s_0+\ell+\Delta h} \equiv g^{a+h(m_1)+n} \pmod{n}.$$

Bilinearity therefore yields

$$\begin{aligned} e_n([g^{s_1}]P, S_1) &= e_n(P, G_H)^{g^{s_0+\ell+\Delta h} \kappa_1} \\ &= e_n(P, G_H)^{g^{a+h(m_1)+n} \kappa_1} \\ &= e_n([g^{h(m_1)+n}]Q, H(m_1)), \end{aligned}$$

which is the target verification equation. $\square$

The attacker copies s_0 exactly, so it automatically preserves every scalar range restriction satisfied by the oracle response. It uses no secret key, factorization, discrete logarithm, $\varphi(n)$, nonce collision, or malformed point. After one query, the same computation applies independently to every fresh encodable target.

4.1 Range-sampled alternative

A second form makes the message-independent point explicit:

$$c = s_0 - h(m_0), \quad U = [\kappa_0^{-1}]S_0.$$

For a fresh candidate m_* , set

$$s_* = c + h(m_*), \quad S_* = [\kappa_*]U.$$

The hidden modular wrap in s_0 does not affect verification because powers of g are periodic modulo $\varphi(n)$. If the verifier is expected to apply the signer-only range $s_* < \varphi(n)$, the attacker samples public targets until

$$1 \leq s_* \leq n - 2^{1025}.$$

The advertised factor bound $p_1, p_2 < 2^{1024}$ gives $\varphi(n) = n - p_1 - p_2 + 1 > n - 2^{1025}$, so this public test guarantees the hidden range condition. The same- s attack is stronger because it needs no target sampling or bound.

5 Full-parameter implementations

Both reproductions use the paper’s printed factors and therefore the exact composite-order scale:

$$|p_1| = 1023, \quad |p_2| = 1024, \quad |n| = 2046, \quad q = 4n - 1, \quad |q| = 2048.$$

They implement $E : y^2 = x^3 + x$ over $\mathbb{F}_q$, $\mathbb{F}_{q^2} = \mathbb{F}_q[i]/(i^2 + 1)$, the distortion map $(x, y) \mapsto (-x, iy)$, a Miller loop at composite order n , and final exponent $(q^2 - 1)/n = 4(q - 1)$. The pairing sanity checks establish nontriviality, exact order n , and bilinearity on independent small scalars.

The paper leaves h , the KDF, byte framing, the sign bit, and point encodings abstract. Both implementations use domain-separated SHAKE256 and compressed affine points. The attack depends only on the public κ_m exposed by the specified map and not on a collision or biased hash output.

5.1 Primary reconstruction

The primary implementation uses the published factors, $g = 2$, and $a = 2^{256} + 2^9 + 1$. Its fixed query is

`authorized one-query source message`

and its unsigned target is

`fresh target message never submitted to the signer.`

The strict verifier decodes the affine point, checks the public scalar range, checks $[n]S = \mathcal{O}$, and evaluates both sides of Equation (3). An honest signature was accepted, the source signature was rejected on the target, the same- s forgery was accepted on the fresh target, and changed-message and altered-scalar controls rejected.

The frozen run took 104.40 seconds wall time and 16,896 KiB peak resident memory on one worker. A separate replay of the same frozen source took 105.35 seconds and 17,408 KiB; it repeated all pairing and attack checks.

5.2 Independent fresh-key reconstruction

The second implementation independently generates a new exact-order subgroup generator, secret exponent, public point, and signing split at the same endpoint. Its fixed source and preselected target are

`single chosen-message signing query`
`fixed fresh target chosen before the attack.`

Neither attack function receives $p_1, p_2, \varphi(n), a, k$, or ℓ ; the factors remain only in key generation and observer assertions.

The ordinary verifier accepted the honest query, the fixed-target same- s forgery, and the independently exercised range-sampled forgery. It rejected the same forgery after changing the message, point, point sign, or scalar, and rejected both the identity encoding and an order-two non-subgroup point. The same- s attack took 2.349 seconds and its pairing verification 18.827 seconds. The range-sampled form found a target on its first attempt, took 4.540 seconds, and passed verification. The complete run, including key generation, three accepted pairing verifications, and all controls, took 156.744 seconds internally (156.83 seconds wall time) and 17,920 KiB peak resident memory on one worker.

Table 1: Recorded full-parameter executions. Times are wall or internal wall times on one worker; they are reproducibility measurements rather than optimized benchmarks.

Execution	Full run (s)	attack only (s)	peak KiB	Outcome
Primary frozen run	104.40	included	16,896	pass
Primary root replay	105.35	included	17,408	pass
Independent fresh key, same- s	156.744	2.349	17,920	pass
Independent fresh key, ranged	same run	4.540	same run	pass

6 Printed example defects and evidence boundary

The full-scale endpoint is usable, but the two printed points cannot be taken verbatim.

1. The printed decimal $y(P)$ has an extra digit at zero-based index 587 and is not on the curve. Taking the square root determined by the printed $x(P) = 2^{1500} + 2$ repairs the coordinate.
2. The repaired printed P has order $2n$, with $[n]P = (0, 0)$ and $[2n]P = \mathcal{O}$, rather than the claimed order n .
3. The printed Q is on the curve and matches $[2^a]P$ for that repaired order- $2n$ point, so it has the same subgroup mismatch. The primary implementation doubles both points, obtaining exact-order- n points that preserve $Q = [2^a]P$.
4. Although the text calls both factors 1024-bit primes, the printed p_1 is 1023 bits and p_2 is 1024 bits.

The independent implementation avoids these point defects entirely by generating a new conforming exact-order point. It reaches the same attack result, establishing that the forgery is not caused by repair of the example.

The Section 4 sampler also permits $\kappa_m = 0$, while the advertised signature format cannot encode the resulting identity point by an affine x -coordinate. Our universal-forgery statement covers every target for which the scheme’s own signature representation is defined. This negligible encoding gap neither enables nor assists the attack.

The following hashes bind the executable evidence used for this report:

Artifact	SHA-256
Frozen primary source	dda52b3d3e6e34a0b238ee7034e30f2030f82547e6831d56d6f985251f8fd255
Primary replay output	eabe8dc9ff3d32cfe1bb5211ee133a5ebd1140df2b76164fa10ed24423581ff2
Independent source before editorial comment fixes	6c4c3c675dc474841ea19d09b6c37ac5c663d0c0445f376c548c096fa04718dc
Independent final output	9d019f15e0335c350507a5078f3fb5cbcbcb754f73f977b5131b3f8a6ec32d08
Public primary core	9b2c4c22ca98a983d7e7df0797f269c32d5cdd838f0956bbb697dc646d4ac921
Public independent core	49bf7d87a5904550f2f0cef911c56fa93827aafb83cb7b5c86206825cb5bcb3a

The public copies change only explanatory comments and docstrings: they correct the factor-size wording, identify G_H rather than P as the Section 4 map base used by the implementation, and remove development provenance. Executable logic is unchanged.

7 Repair and limitations

The direct cause is Equation (4): public map evaluation exposes a discrete logarithm of every output with respect to the same public base. Changing that base from P to an unrelated public point does not

help, as Tibouchi’s BLS analysis already shows; the attack needs scalar ratios, not the base’s discrete logarithm.

A repair should replace Section 4 with a standard hash-to-group construction whose outputs do not carry publicly known discrete logarithms relative to a fixed base. The signing and verification equations then require a new security proof under a precisely stated hash-to-group model. Implementations should also specify byte encodings, reject the identity, validate subgroup membership, and define the public scalar range. These validation rules are sound engineering requirements, but the reproduced strict verifiers show that they do not stop the present transport.

This report demonstrates a design attack at one concrete endpoint because v2 publishes one full numerical example. Its proof is parameter-independent for every well-formed key satisfying the stated equations. The work does not claim secret-key recovery, factorization, or a break of the underlying pairing, discrete-logarithm, or factoring assumptions. The stronger direct forgery already violates existential unforgeability under chosen-message attack.

8 Reproducibility

The public package uses only Python’s standard library. From the attack directory, run

```
python3 reproduce.py
python3 reproduce-all-rows.py
```

or execute `reproducer/reproduce.sh`. The first command runs the primary published-example reconstruction; the second independently generates new key material at the sole published endpoint. Canonical outputs are stored in `reference-output.json` and `all-rows-reference-output.json`. Timing fields vary by machine.

The implementation is intentionally direct rather than optimized. It uses affine curve arithmetic and pure-Python extension-field operations so every group and pairing step remains inspectable. Peak memory stayed below 18 MiB in the recorded runs; each command occupies one CPU.

9 Conclusion

Poulakis–Rolland v2 publishes the scalar representation of every hash-to-group output. One valid signature therefore supplies a point that can be rescaled, together with public message-dependent powers of g , into a valid signature for any fresh encodable target. Keeping the integer response unchanged makes the attack compatible with strict range, decoding, and subgroup checks. Two full-parameter modified Tate-pairing implementations, including one with new key material, accept the forgery and reject the negative controls. Repair requires a new hash-to-group construction and a new proof for the resulting scheme.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

- [1] D. Poulakis and R. Rolland. A digital signature scheme based on two hard problems. Cryptology ePrint Archive, Paper 2012/134, revision 20150430:055329, 2015. <https://eprint.iacr.org/2012/134>.
- [2] M. Tibouchi. *Hachage vers les courbes elliptiques et cryptanalyse de schémas RSA* (Hashing to elliptic curves and cryptanalysis of RSA-based schemes). Ph.D. thesis, Université Paris Diderot and University of Luxembourg, 2011. Section 3.2, pp. 38–40. <https://hdl.handle.net/10993/15584>.
- [3] D. Boneh, B. Lynn, and H. Shacham. Short signatures from the Weil pairing. *Journal of Cryptology*, 17(4):297–319, 2004. Preliminary version in ASIACRYPT 2001. <https://doi.org/10.1007/s00145-004-0314-9>.